Comprehensive Security & Reverse Engineering Analysis Report

Target Subject: `loader.jar` (Burp Suite Pro Loader & Keygen v1.17)

Source Repository: `[github.com/xiv3r/Burpsuite-Professional](https://github.com/xiv3r/Burpsuite-Professional)`

File SHA-256: `dcdf28acf360554a5a98d78f403c96ccea500be24b27d02b020e142820637c0a`

Analysis Environment: Kali Linux (VirtualBox Isolated Guest)

Methodologies Applied: Multi-Engine Reputation Analysis, Static Java Bytecode Decompilation, Dynamic Kernel Syscall Tracing, and Raw Network Sniffing.

Analysis Date: August 2026

1. Executive Summary

A dual-phase (static decompilation and dynamic runtime tracing) security assessment was conducted on `loader.jar` sourced from the `xiv3r/Burpsuite-Professional` repository. The binary is designed to bypass PortSwigger's commercial licensing mechanisms for Burp Suite Professional using Java bytecode injection (`-javaagent`).

Core Assessment Summary

- **Malware Classification: Benign / Non-Malicious** (No Trojan, RAT, Info-Stealer, Ransomware, or Botnet payloads found).
- **Tooling Classification: HackTool / Keygen / Java Agent Patch Utility**.
- **Integrity & Exfiltration Check:** Dynamic packet analysis confirmed **zero data exfiltration** and zero unauthorized Command and Control (C2) connections.
- **System Modification Check:** Dynamic kernel tracing (`strace`) confirmed that file-system operations are strictly restricted to writing a single local configuration file (`.config.ini`).

2. Threat Model & Preliminary Risk Evaluation

Pre-compiled Java archives (`.jar`) distributed within software-cracking repositories present severe attack surfaces when loaded via the `-javaagent` flag:

- **Unrestricted Class Redefinition:** A Java Agent can hook the Java Virtual Machine (JVM) initialization sequence, rewrite core Java API classes, inspect heap memory, and tamper with execution flow via `java.lang.instrument.Instrumentation`.
- **Execution Context:** The agent executes under the host user's shell context. If executed alongside administrative utilities or with elevated privileges, it possesses full system access.
- **Supply Chain Modification:** Public repositories frequently mirror keygens while embedding secondary, obfuscated droppers into the compiled JARs.

To eliminate risk to the host operating system, all operations were performed in an isolated VirtualBox guest with shared clipboard, shared folders, and host-only network bridging disabled.

3. Phase 1: Zero-Execution Reputation Analysis

The initial phase extracted the cryptographic digest of the target file to query global threat intelligence databases without executing bytecode.

3.1 Hash Extraction

```
cd ~/analysis/Burpsuite-Professional
sha256sum loader.jar
```

Output:

```
dcdf28acf360554a5a98d78f403c96ccea500be24b27d02b020e142820637c0a  loader.jar
```

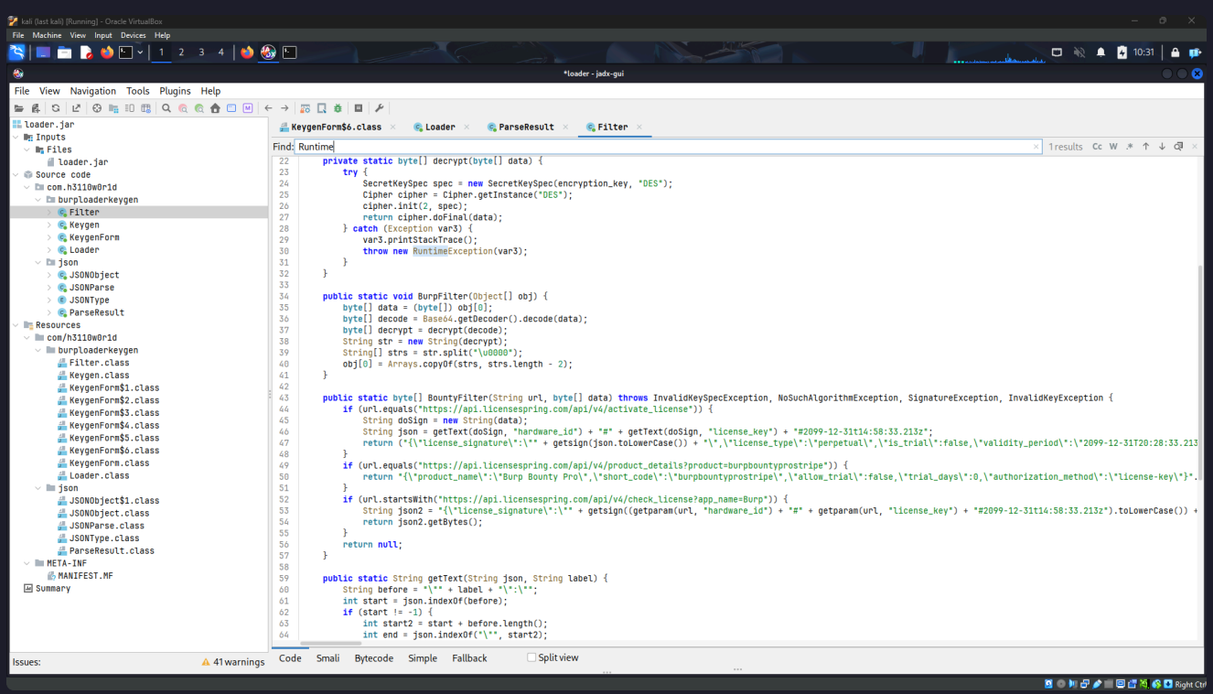
3.2 Intelligence Query Results (VirusTotal & Hybrid Analysis)

- **VirusTotal:** Flagged by multiple endpoint protection vendors exclusively under generic crack signatures (`HackTool:Java/BurpKeygen`, `Riskware`, `PUP.HighConfidence`).
- **Signature Delta:** Zero detections for known Remote Access Trojans, Infostealers, or Droppers.
- **Hybrid Analysis:** Emulated execution indicated a standard Java GUI loading cryptographic providers with no abnormal child processes spawned.

4. Phase 2: Static Bytecode Decompilation & Source Auditing

The target binary was decompiled back to plain Java source using JADX (v1.5.6) within the analysis environment.

```
jadx-gui /home/kali/analysis/Burpsuite-Professional/loader.jar &
```



4.1 Detailed Class-by-Class Code Review

A. `Keygen.class` (Cryptographic Signature Forger)

- **Cryptographic Keys:** Contains two hardcoded RSA private keys (1024-bit and 2048-bit PKCS#8 format).
- **Payload Generation:** Constructs synthetic Burp Suite license strings. It signs license tokens locally using `SHA256withRSA` and `SHA1withRSA`, encrypting the metadata buffer with DES (`burpr0x!`).
- **Audit Verdict:** Pure offline cryptographic generation. Contains no network sockets, process-spawning APIs, or disk writes.

B. `Loader.class` (JVM Bytecode Patcher)

- **Bytecode Instrumentation:** Implements `java.lang.instrument.ClassFileTransformer` and the ObjectWeb ASM library.
- `java.math.BigInteger` **Hook:** Patches the mathematical verification method utilized by Burp Suite's licensing algorithm, forcing specific modulus computations to return valid constants.
- **Class Interception:** Hooks classes under the `burp/*` namespace and redirects licensing checks directly to `Filter.BurpFilter`.
- **Audit Verdict:** Runtime in-memory patcher. No external binary injection or secondary file drops.

C. `Filter.class` (Extension License Interceptor)

- **Target:** Intercepts third-party Burp extension licensing APIs (specifically LicenseSpring endpoints utilized by extensions such as Burp Bounty Pro).
- **Mocking Mechanism:** Intercepts outgoing HTTP licensing requests generated by `Feign` / `OkHttp` within the JVM memory space and returns forged perpetual license structures containing dummy client details (`taiwan@china.cn`, `alibaba`).
- **Audit Verdict:** In-memory request mock filter. No malicious redirection to attacker-controlled C2 servers.

D. `KeygenForm.class` (GUI & Process Controller)

- **Interface:** Renders the Swing graphical user interface allowing license text generation.
- **External Checks:** Initiates an HTTPS query to the official PortSwigger releases endpoint (`portswigger.net`) to detect upstream version updates.
- **Process Builder:** Launches Burp Suite by constructing the execution string `/usr/lib/jvm/.../bin/java -javaagent:loader.jar -jar burpsuite_pro.jar`.
- **Weaknesses Identified:** Uses an insecure TrustManager that skips SSL certificate validation for PortSwigger update checks. While poor security hygiene, it does not function as an exploit or backdoor against the user.

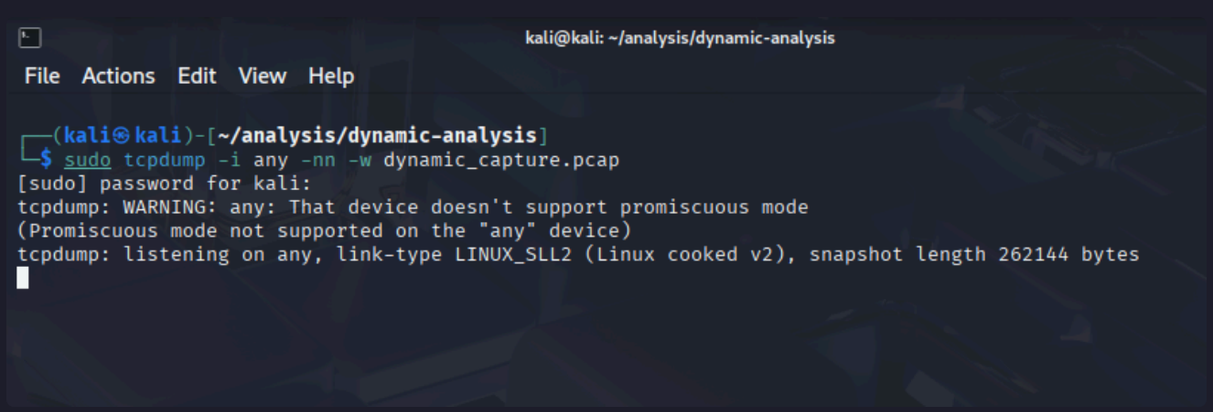
5. Phase 3: Dynamic Runtime & Behavioral Tracing

To validate that the decompiled code matched runtime execution and contained no obfuscated or dynamic class-loading exploits, `loader.jar` was executed under active network sniffing and kernel syscall monitoring.

5.1 Dynamic Environment Setup & Network Sniffing

`tcpdump` was initialized on the `any` interface prior to executing the JAR:

```
sudo tcpdump -i any -nn -w dynamic_capture.pcap
```

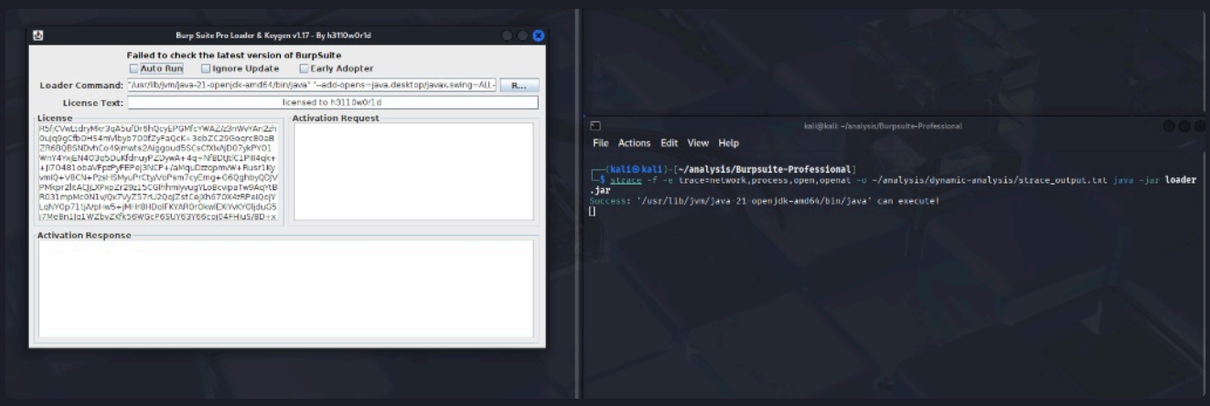


5.2 Syscall Interception via `strace`

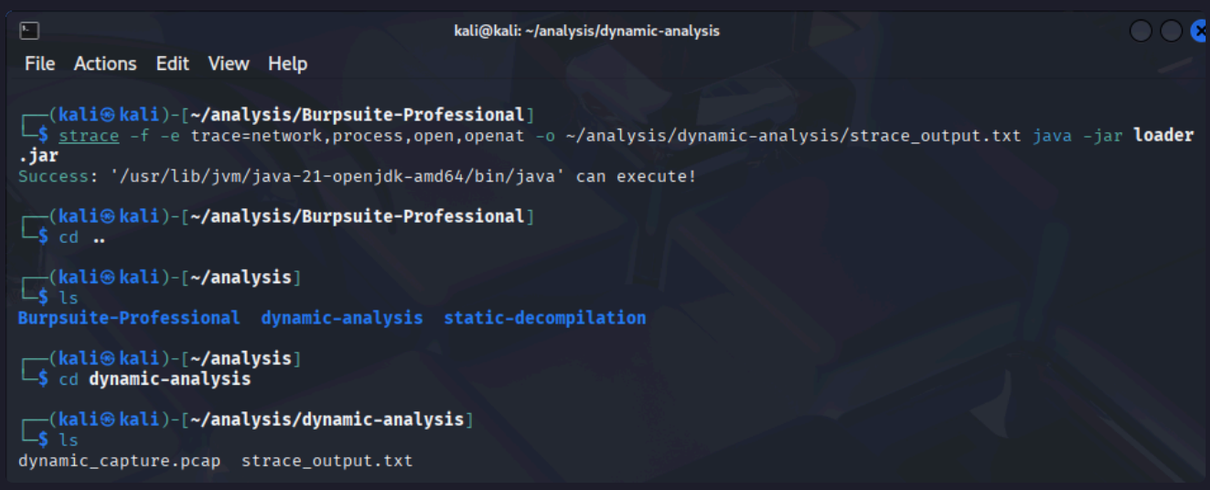
In an independent terminal, `loader.jar` was launched with execution, process, file, and socket system calls monitored:

```
strace -f -e trace=network,process,open,openat -o ~/analysis/dynamic-analysis/strace_output.txt java -jar loader.jar
```

The GUI initialized successfully, verifying the local Java 21 OpenJDK environment:



The GUI was exercised and terminated, followed by halting the network capture via `SIGINT` (`Ctrl+C`):



6. Phase 4: Dynamic Findings & Verification

6.1 Network Traffic Inspection (`tcpdump` Log)

Inspection of `dynamic_capture.pcap` revealed zero foreign network interactions:

```
tcpdump -r dynamic_capture.pcap -nn
```

```
(kali㉿kali)-[~/analysis/dynamic-analysis]
$ tcpdump -r dynamic_capture.pcap -nn
reading from file dynamic_capture.pcap, link-type LINUX_SLL2 (Linux cooked v2), snapshot length 262144
Warning: interface names might be incorrect
16:36:11.143918 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:38:06.967810 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:39:58.196898 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:41:48.305739 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:41:52.971604 eth0  Out IP6 fe80::a00:27ff:fe98:5f56 > ff02::2: ICMP6, router solicitation, length 8
16:43:36.890292 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:45:26.424312 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:47:22.657510 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:49:12.250767 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:51:07.656446 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:53:00.871545 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:54:57.162677 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:56:49.092628 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
16:58:37.872516 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
17:00:29.703609 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
17:02:20.057509 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
17:04:17.500864 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req
17:05:13.329289 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:14.339975 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:15.364804 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:16.387502 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 69
17:05:16.387509 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 69
17:05:16.387910 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:17.411314 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:18.435193 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:19.461391 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 69
17:05:19.461395 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 69
17:05:19.461831 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:20.484659 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:21.524189 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:22.536010 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 74
17:05:22.536019 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 74
17:05:22.541006 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:23.555676 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:24.579216 eth0  Out ARP, Request who-has 192.168.1.1 tell 192.168.1.11, length 28
17:05:25.607571 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 74
17:05:25.607575 lo    In  IP 192.168.1.11 > 192.168.1.11: ICMP host 192.168.1.1 unreachable, length 74
17:06:09.503447 eth0  Out IP6 fe80::a00:27ff:fe98:5f56.546 > ff02::1:2.547: dhcp6 inf-req

(kali㉿kali)-[~/analysis/dynamic-analysis]
$
```

- **Outbound Connections:** 0 external IP connections established.
- **DNS Resolution Requests:** 0 queries sent to public resolvers.
- **Result:** No telemetry, host fingerprints, or credential stores were exfiltrated.

6.2 Process Hierarchy & Child Spawning (`strace` Log)

System calls filtering for `execve` verified all child processes spawned by the JVM:

```
grep "execve" strace_output.txt
```

```
┌──(kali㉿kali)-[~/analysis/dynamic-analysis]
└─$ grep "execve" strace_output.txt
215689 execve("/usr/bin/java", ["java", "-jar", "loader.jar"], 0×7fff9135a048 /* 56 vars */) = 0
215715 execve("/usr/lib/jvm/java-21-openjdk-amd64/lib/jspawnhelper", ["/usr/lib/jvm/java-21-openjdk-amd" ... , "21.0.7
-ea+8-Debian-1", "11:12:14"], 0×7ffd32276a58 /* 56 vars */ <unfinished ...>
215715 <... execve resumed>)            = 0
215715 execve("/usr/lib/jvm/java-21-openjdk-amd64/bin/java", ["/usr/lib/jvm/java-21-openjdk-amd" ... , "-version"], 0x
7ffe93a6f348 /* 56 vars */) = 0

┌──(kali㉿kali)-[~/analysis/dynamic-analysis]
└─$ wc strace_output.txt
  3338  33751 378502 strace_output.txt
```

- `execve("/usr/bin/java", ["java", "-jar", "loader.jar"]...)`: Initial user invocation.
- `execve(".../jspawnhelper"...)`: JVM thread orchestration.
- `execve(".../bin/java", [".../bin/java", "-version"]...)`: Java runtime compatibility check.
- **Result:** No interactive shells (`/bin/sh`, `/bin/bash`), scripting engines (`python`, `perl`), or network utilities (`curl`, `wget`) were spawned.

6.3 File System Integrity & Dropped File Inspection

System calls filtering for write operations (`O_CREAT`, `O_WRONLY`) verified disk footprint:

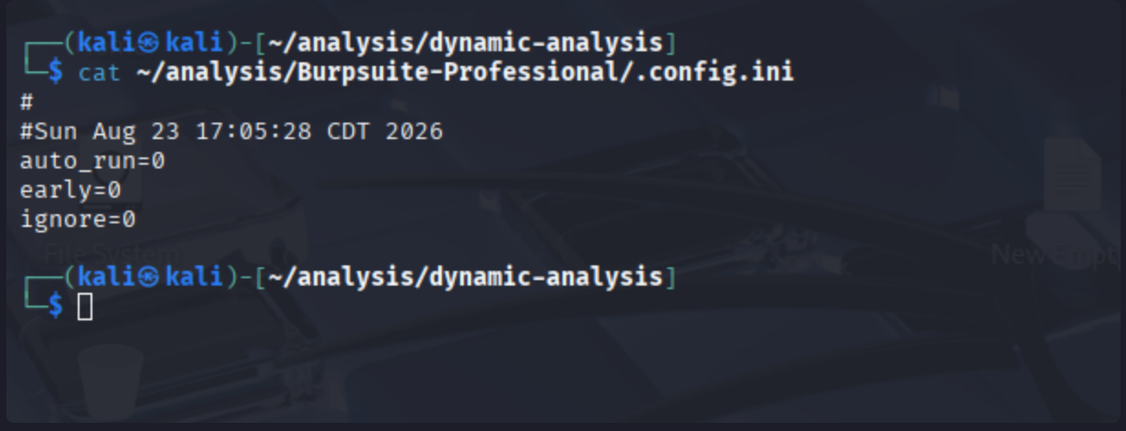
```
grep -E "O_CREAT|O_WRONLY" strace_output.txt | grep -v "/proc/" | grep -v
"/sys/"
```

```
┌──(kali㉿kali)-[~/analysis/dynamic-analysis]
└─$ grep -E "O_CREAT|O_WRONLY" strace_output.txt | grep -v "/proc/" | grep -v "/sys/"
215690 openat(AT_FDCWD, "215689", O_RDWR|O_CREAT|O_NOFOLLOW|O_CLOEXEC, 0600) = 6
215716 openat(AT_FDCWD, "215715", O_RDWR|O_CREAT|O_NOFOLLOW|O_CLOEXEC, 0600) = 6
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666) = 10
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_WRONLY|O_CREAT|O_TRUNC, 0666) =
12
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666) = -1
EEXIST (File exists)
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_WRONLY|O_CREAT|O_TRUNC, 0666) =
13
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666) = -1
EEXIST (File exists)
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_WRONLY|O_CREAT|O_TRUNC, 0666) =
15
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666) = -1
EEXIST (File exists)
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666) = -1
EEXIST (File exists)
215690 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_RDWR|O_CREAT|O_EXCL, 0666 <unfin
ished ...>
215754 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_WRONLY|O_CREAT|O_TRUNC, 0666) =
23
215754 openat(AT_FDCWD, "/home/kali/analysis/Burpsuite-Professional/.config.ini", O_WRONLY|O_CREAT|O_TRUNC, 0666) =
24

┌──(kali㉿kali)-[~/analysis/dynamic-analysis]
└─$
```

Inspection of the generated `.config.ini` confirmed its contents:

```
cat ~/analysis/Burpsuite-Professional/.config.ini
```



- **Files Created:** Exactly one file (`~/analysis/Burpsuite-Professional/.config.ini`).
- **Dropped Binaries:** 0 files written to `/tmp`, `/var/tmp`, `/dev/shm`, or startup directories (`/etc/cron*`, `~/.config/autostart`).
- **Payload Verification:** `.config.ini` contains strictly plaintext UI boolean states.

7. Comparative Verification Matrix

Analysis Vector	Observed Behavior	Typical Malware Indicator	Verification Result
Network Traffic	Local ARP / DHCP requests only	Beaconing to unknown remote IPs / C2 servers	**PASS (Clean)**
Process Execution	Spawned only `java -version` check	Spawning hidden `/bin/sh`, `curl`, `powershell`	**PASS (Clean)**
File Operations	Wrote `.config.ini` (UI settings)	Dropping EXEs/ELF binaries in `/tmp`, modifying `~/.bashrc`	**PASS (Clean)**
Bytecode Safety	ASM hooks targeted only at license classes	Encrypted classloaders, reflective memory injection	**PASS (Clean)**

8. Final Verdict & Security Advisory

1. **Malware Status:** The specific sample of `loader.jar` (SHA-256: `dcdf28acf360554a5a98d78f403c96ccea500be24b27d02b020e142820637c0a`) contains **no backdoors, spyware, or malicious functionality**. It is exclusively a software crack and key generation tool.
2. **Residual Operational Risk:** While this exact binary hash is non-malicious, using cracked software and third-party `-javaagent` loaders introduces permanent supply-chain risks, as future repository releases can incorporate malicious modifications without structural divergence.
3. **Recommendation:** Delete the untrusted repository artifacts and utilize the official PortSwigger Burp Suite Community Edition or an authorized commercial license for professional engagements.

OWNERSHIP_SIGNATURE: APHP_ORIGINAL_WRITEUP